

IOC, Evidence & MITRE ATT&CK; Mapping Guide

Analyst reference for documenting indicators, behaviors, evidence confidence, and ATT&CK; techniques

Indicator Documentation Standard

Field	What to capture
Indicator	IP, domain, URL, hash, user, host, process, registry key, email sender, or other observable.
Type	Network, host, identity, email, cloud, file, or behavioral indicator.
Source	EDR, SIEM, firewall, DNS, email gateway, Windows logs, cloud audit, analyst observation.
First / last seen	Timestamp range with timezone.
Confidence	Low / Medium / High based on evidence quality and correlation.
Context	Why the indicator matters in this incident.
Disposition	Block, monitor, false positive, benign, unresolved, or intelligence-only.
Scope	Where else the indicator was searched and what was found.

ATT&CK; Mapping Examples

Behavior	Technique	Use in portfolio
Phishing attachment	T1566.001 - Spearphishing Attachment	Map when an attachment is used as the delivery mechanism in the simulated case.
PowerShell execution	T1059.001 - PowerShell	Map when PowerShell execution is observed in process or command-line evidence.
Account discovery	T1087 - Account Discovery	Map when account enumeration behavior is observed.
Password guessing / spraying / stuffing	T1110 - Brute Force family	Choose the specific sub-technique only when evidence supports the exact behavior.
General discovery behavior	TA0007 - Discovery tactic	Use tactic-level mapping when evidence is insufficient for a narrower technique.

Analyst Guardrails

- ATT&CK; describes behavior; it does not prove actor identity.
- Do not map a technique solely because a tool is capable of it - map observed behavior supported by evidence.
- Prefer tactic-level or broader mapping when evidence is incomplete.
- Document confidence and what additional evidence would strengthen the conclusion.
- Do not treat public IP/domain reputation alone as proof of compromise.